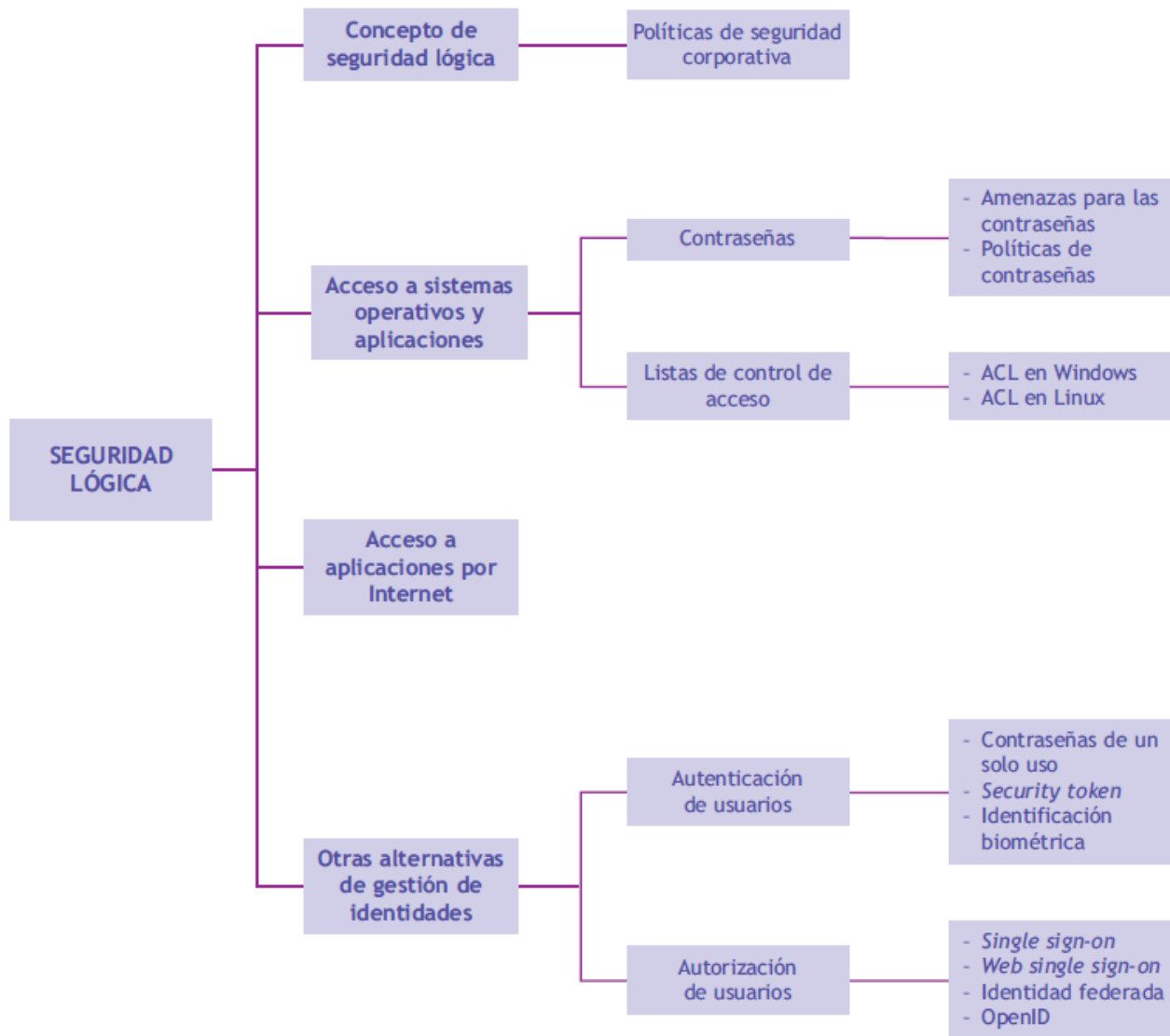


unidad

3

Seguridad lógica



CONCEPTO DE SEGURIDAD LÓGICA

Enorme **interconexión** existente entre los sistemas con la implantación masiva de Internet y las redes de datos



Seguridad lógica → Foco de atención de las organizaciones

Esto es así porque los sistemas pueden ser comprometidos de forma remota por un atacante a través de una red mal protegida o aprovechando un sistema sin los adecuados sistemas de seguridad.

La **seguridad lógica** es el conjunto de medidas destinadas a la protección de los datos y aplicaciones informáticas, así como a garantizar el acceso a la información únicamente por las personas autorizadas.

CONCEPTO DE SEGURIDAD LÓGICA

Políticas de seguridad corporativa

La primera medida de seguridad lógica que debe adoptar una empresa es establecer unas **normas claras** en las que se indique qué se puede y qué no se puede hacer al operar con un sistema informático.

El conjunto de normas que definen las medidas de seguridad y los protocolos de actuación a seguir en la operativa del sistema reciben el nombre de **políticas de seguridad corporativa** en materia informática

- ✓ Implicación de todos los departamentos
- ✓ Medidas o mecanismos:
 - ✓ Autenticación de usuarios
 - ✓ Listas de control de acceso
 - ✓ Criptografía
 - ✓ Certificados digitales
 - ✓ Firmas digitales
 - ✓ Cifrado de unidades de disco o sistemas de archivos

Mecanismos establecidos en las políticas de seguridad

- **Autenticación de usuarios:** sistema que trata de evitar accesos indebidos a la información a través de un proceso de identificación de usuarios, que en muchos casos se realiza mediante un nombre de usuario y una contraseña.
- **Listas de control de acceso:** mecanismos que controlan qué usuarios, roles o grupos de usuarios pueden realizar qué cosas sobre los recursos del sistema operativo.
- **Criptografía:** técnica que consiste en transformar un mensaje comprensible en otro cifrado según algún algoritmo complejo para evitar que personas no autorizadas accedan o modifiquen la información.
- **Certificados digitales:** documentos digitales, identificados por un número de serie único y con un periodo de validez incluido en el propio certificado, mediante los cuales una autoridad de certificación acredita la identidad de su propietario vinculándolo con una clave pública.
- **Firmas digitales:** es el conjunto de datos, en forma electrónica, consignados junto a otros o asociados con ellos que pueden ser utilizados como medio de identificación del firmante. Ejemplo: DNI electrónico.
- **Cifrado de unidades de disco o sistemas de archivos:** medidas que protegen la confidencialidad de la información.

ACCESO A SSOO Y APLICACIONES

Para acceder a la información almacenada en un sistema informático en primer lugar hay que superar las barreras físicas de acceso. Una vez superadas estas barreras, el siguiente paso en materia de seguridad será establecer unas **barreras lógicas** que impidan el acceso a nuestros datos.

Contraseñas

Una contraseña es un sistema de autenticación de usuarios compuesto por una combinación de símbolos (números, letras y otros signos).

Sistema multiusuario: cada persona debe tener usuario y contraseña

Amenazas para las contraseñas: se ha de obligar a los usuarios a cumplir unas determinadas normas a la hora de seleccionar sus contraseñas para hacerlas lo más fuertes posibles. A pesar de ello, existen sistemas para tratar de averiguar contraseñas. Los más comunes son: *sniffers*, *keyloggers*, ataques por fuerza bruta, ataques por diccionario y ataques por ingeniería social.

Mecanismos para averiguar contraseñas

- Utilización de **sniffers**: programas que registran la actividad de un equipo informático y pueden interceptar las comunicaciones “escuchando” para obtener datos como las contraseñas.
- Uso de **keyloggers**: son programas o dispositivos cuyo fin es capturar las pulsaciones en un teclado, con lo que se pueden obtener las contraseñas que han sido escritas con ese teclado.
- **Ataques por fuerza bruta**: consisten en probar todas las combinaciones posibles de caracteres hasta encontrar la clave que permite acceder al sistema. Por esto, cuanto más larga sea la cadena de caracteres que tenga la clave más se dificulta el acceso, pues más tiempo requiere averiguar la contraseña.
- **Ataques por diccionario**: consisten en generar diccionarios con términos relacionados con el usuario y probar todas esas palabras como contraseñas para acceder a ese sistema. Suelen ser más eficaces que los ataques por fuerza bruta, ya que los usuarios tienden a establecer como contraseñas palabras de su idioma, pues son más fáciles de recordar.
- **Ataques por ingeniería social**: consisten en engañar a los usuarios para que proporcionen sus contraseñas a los intrusos, haciéndose estos pasar por amigos, empleados de un banco, técnicos, etc.

Políticas de seguridad en materia de contraseñas

Es esencial que los usuarios y empresas establezcan unas políticas de seguridad relativas a las contraseñas.

Establecimiento de contraseñas: elegir contraseñas en función de su idoneidad para proteger la información, no en función de su facilidad para ser recordadas por el usuario → Normas para la elección de contraseñas que **dificulten los ataques** por diccionario o por fuerza bruta. Cambiarlas.

Comunicación de contraseñas: Vigilar la comunicación de las contraseñas por parte del usuario. ¡Ojo con correos de restablecimiento de contraseñas o números de tarjeta o PIN! Cuidado con WIFI's abiertas. Encriptar

Almacenamiento de contraseñas: Recomendable uso de programas gestores de contraseñas. → ¡¡¡Seguridad física y lógica van de la mano!!!

Papel del administrador: Medidas adicionales que fuercen al usuario a obedecer las normas de seguridad. Compromiso entre la facilidad de gestión y el nivel de seguridad requerido.

Listas de control de acceso

Puede ser necesario realizar un ajuste más riguroso para restringir el acceso a los recursos del sistema → Utilizar las listas de control de acceso o ACL.

Las **ACL** son una herramienta que permite controlar qué usuarios pueden acceder a las distintas aplicaciones, sistemas, recursos, dispositivos, etc. También se aplican masivamente en servicios básicos de red tales como *proxy*, servidores DNS, servidores de correo electrónico, etc.

ACL en Windows: las opciones de compartición de recursos van a depender del sistema de archivos con el que se trabaje → **NTFS**

- Permite aprovechar al máximo las ventajas de la compartición de recursos y la asignación de permisos avanzada
- Cada fichero y cada directorio tiene una lista de control de acceso o permisos NTFS.
- Para cada usuario que tiene acceso a un directorio o a un fichero existe una entrada de acceso que indica el tipo de operaciones que puede realizar. Se distinguen dos tipos de privilegios de acceso:
 - Permisos: forma de acceder a un objeto concreto.
 - Derechos: establece qué acciones se pueden realizar en el sistema.

Para cada objeto se establece una lista de usuarios/grupos y a cada uno de ellos se les aplican los permisos pertinentes: Esta lista se llama **ACL (Access Control List)**. Cada entrada de la ACL se llama **ACE (Access Control Entry)**

Permisos en Linux

- ✓ en Linux, todos los usuarios pertenecen a un grupo principal y, además, pueden pertenecer a otros secundarios.
- ✓ El usuario administrador del sistema se denomina *root* y tiene todos los privilegios del sistema.
- ✓ Cada fichero o directorio pertenece a un usuario y, por tanto, a uno de los grupos a los que pertenece el usuario.
- ✓ Los permisos de cada fichero o directorio se ajustan para el usuario propietario (u), para su grupo (g) y para el resto (o).
- ✓ Estos permisos aplicados implican que el recurso puede leerse (r), ser editado (w) o ser ejecutado (x).
- ✓ Existe máscara o patrón: 644(rw-r—r--) para ficheros, 755 (rwxr-xr-x) para directorios

#setfacl
#getfacl

ACL en Linux

- ✓ En ocasiones, estos permisos no serán suficientes para establecer restricciones a los usuarios de un sistema, por ello se utilizan las **ACL**.
- ✓ Si las ACL están habilitadas, para activarlas en una partición o directorio hay que añadir la palabra **acl** al final de la línea correspondiente a dicha partición en el fichero `/etc/fstab`.
 - ✓ Ejemplo: `#mount -o remount acl /dev/sda3 /home`
- ✓ Una ACL está compuesta por varias entradas, cada una de las cuales especifica los permisos de acceso a un recurso para un usuario o un grupo, utilizando una combinación de los permisos tradicionales.

- ◉ Una ACL está compuesta por varias entradas, cada una de las cuales especifica los permisos de acceso a un recurso para un usuario o un grupo, utilizando una combinación de los permisos tradicionales de lectura (r), escritura (w) y ejecución (x).
- ◉ Estas entradas son:
 - La categoría: usuario (u), grupo (g), otros (o) o máscara (m).
 - UID (identificador de usuario) o GID (identificador de grupo) del usuario o grupo afectado. Este campo puede estar vacío, en cuyo caso la ACL se vincula al usuario propietario o al grupo propietario.
 - Cadena con los permisos asignados.
- ◉ El conjunto de la categoría y el identificador del usuario o grupo definen el tipo de entrada.

Tipo de entrada	Visualización	Descripción
<i>owner</i>	<code>u[ser]::rwx</code>	Privilegios de acceso del propietario.
<i>group</i>	<code>g[roup]::rwx</code>	Privilegios de acceso del grupo propietario.
<i>other</i>	<code>o[ther]::rwx</code>	Privilegios que no corresponden a ninguna entrada (otros).
<i>named user</i>	<code>u[ser]:name:rwx</code>	Privilegios de acceso para los usuarios identificados por una ACL.
<i>named group</i>	<code>g[roup]:name:rwx</code>	Privilegios de acceso del grupo identificado por una ACL.
<i>mask</i>	<code>m[ask]::rwx</code>	Privilegios máximos otorgados a <i>named user</i> , <i>group</i> y <i>named group</i> .

- ◉ Las tres primeras entradas de la tabla se conocen como **ACL estándar** y coinciden con la gestión simple de los permisos: `owner`, `group` y `other`.
- ◉ Las otras tres se conocen como **ACL extendida**, que proporciona mayor flexibilidad, dado que permite otorgar permisos a un usuario concreto indicando su nombre (**named user**), a un grupo concreto indicando su nombre (**named group**) o utilizando una máscara (**mask**).
- ◉ El orden de aplicación de reglas es el siguiente: `owner`, `named user`, `owning group`, `named group` y `other`.
- ◉ La máscara se aplica sobre cualquier entrada, a excepción de `owner` y `other`, esto es, actúa sobre las entradas de tipo `named user`, `owning group` y `named group`.

ACCESO A APLICACIONES POR INTERNET

- Es importante **garantizar y proteger la identidad de los usuarios** cuando se identifican en una página web.
- Las páginas web se deben configurar de modo que la **transferencia de datos** con los usuarios sea **segura**, especialmente, si estos datos son sensibles.
- Existen unas **normas generales** aplicables a todas las aplicaciones que ponen especial énfasis en el eslabón más débil de la cadena a efectos de seguridad, el usuario:

- ✓ Mantener actualizados tanto el sistema operativo como el navegador y, el antivirus.
- ✓ Hacer una correcta administración de nombres de usuario y contraseñas.
- ✓ Desconfiar de las web que introduciendo un nuevo correo te devuelven una contraseña olvidada.
- ✓ Acceder a las distintas aplicaciones de datos muy sensibles desde un ordenador seguro.
- ✓ No facilitar ni modificar las contraseñas por vía telefónica o por correo electrónico.
- ✓ No acceder a través de enlaces: evitar el **phising**
- ✓ Cerrar la sesión correctamente

https

Certificados
digitales

Transacciones
virtuales

Autoridades
certificadoras

OTRAS ALTERNATIVAS DE GESTIÓN DE IDENTIDADES

Dos conceptos básicos:

- ✓ **Autenticación** es lo que permite identificar al usuario (mediante usuario y clave, certificado, etc.)
- ✓ **Autorización** es el mecanismo que decide a qué recursos puede acceder un usuario una vez autenticado.

Autenticación de usuarios

Existen otros métodos de autenticación diferentes a los ya vistos de usuario y contraseña, como por ejemplo:

Contraseñas de un solo uso: se utilizan normalmente en entornos con elevados requerimientos de seguridad. Cada vez que se quiere acceder al sistema se utiliza una contraseña nueva, que tiene un periodo de validez muy corto. Ejemplo: bancos

Security token: Es un pequeño **dispositivo hardware** que autentica al usuario que lo lleva y permite, por ejemplo, su acceso a una red. Se autentifica al usuario por dos factores: su PIN personal y el número que proporciona el token.

Identificación biométrica: Se trata del uso de sistemas que permiten la autenticación de usuarios mediante **características personales** inalterables.

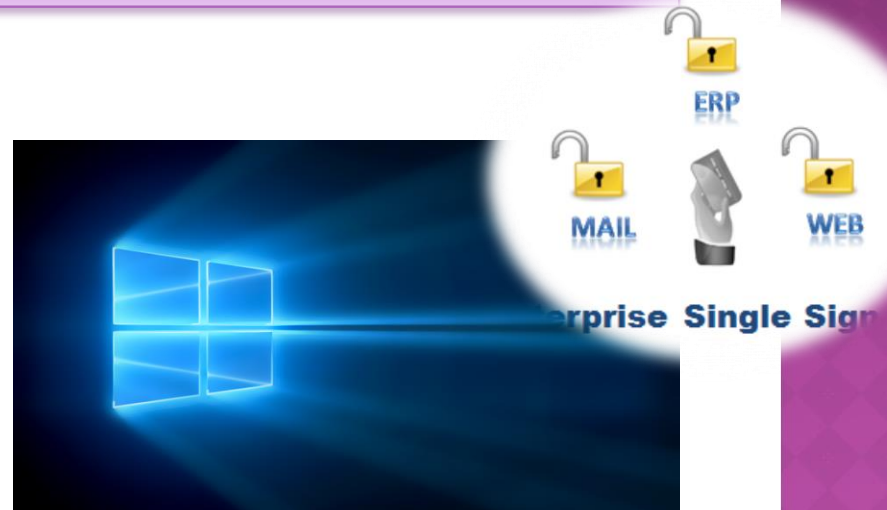
Autorización de usuarios

- ✓ En la operativa habitual de un sistema informático, cada aplicación realiza la autorización de sus usuarios de una manera (por roles, grupos de usuarios, etc.).
- ✓ Cuando se intenta centralizar la autenticación y la autorización de todas las aplicaciones en un único sistema se recurre a los sistemas de Single-Sign-On (SSO)

Single Sign-On (SSO): Existe una única base de datos centralizada con todos los usuarios/contraseñas.

Ejemplo: protocolo de de autenticación **Kerberos** → sistema de generar un ticket para el usuario una vez se ha autenticado.

- ✓ Active Directory + Kerberos → SSO para servicios básicos de la red Windows
- ✓ Otros fabricantes: soporte para integración con AD + integración SSO, AD y aplicaciones



Autorización de usuarios

Web Single Sign-On (Web-SSO):

- ✓ La mayor parte de las aplicaciones que se desarrollan están pensadas para que el usuario acceda a estas mediante su navegador
- ✓ Debido a esto, se han generalizado los sistemas de tipo **web-SSO**, que siguen un sistema semejante al SSO, con la diferencia de que solo sirven para acceso a aplicaciones vía navegador, ya que el ***ticket se intercambia entre el servidor web-SSO y el navegador del cliente, que guarda los datos relativos al ticket en cookies.***

Identidad federada:

- ✓ Consiste en establecer relaciones de confianza entre los distintos sistemas de SSO de forma que los usuarios puedan acceder a las aplicaciones a las que estén autorizados con las mismas credenciales en todas las sedes.

- ✓ Organizaciones grandes con muchos departamentos que comparten algunas aplicaciones y otras no.

OpenID: Sistema abierto. Ofrece la posibilidad de crear una identidad federada entre todos los sitios web que decidan usar este sistema.

- ✓ Distintas webs sin relación entre ellas.